Crittografia Asimmetrica (Public Key)

Cybersecurity – UniPR | Riassunto per l'esame

Slide: 198–239 | Stallings: Cap.9 (pp.542–593), Cap.10 sez.10.1 (pp.594–615)

Domande: Q17, Q18, Q19, Q24, Q25 — Esercizi: Es.15–21

■■ Per gli esercizi RSA (Es.15–18) vedi il PDF dedicato 'Riassunto_RSA.pdf'

1. Principi della Crittografia a Chiave Pubblica

La crittografia asimmetrica (Diffie & Hellman, 1975) usa **due chiavi distinte** per ogni utente: una **chiave pubblica** (nota a tutti) e una **chiave privata** (segreta). Chi cifra o verifica non può decifrare o firmare — le operazioni dei due lati usano chiavi diverse.

Concetto chiave — Trapdoor function:

```
f(x) è facile da calcolare, ma f■¹(y) è computazionalmente impossibile senza una 'trapdoor' (informazione segreta). Esempio: moltiplicare due grandi primi p·q è facile; fattorizzare il risultato n=p·q (senza conoscere p o q) è impossibile.
```

Confronto simmetrica vs asimmetrica:

	Simmetrica	Asimmetrica
Chiavi	1 chiave segreta condivisa	2 chiavi per utente (pubblica + privata)
Distribuzione chiavi	Problema: come condividerla in sicurezza?	Nessun problema: la pubblica è... pubblica
Velocità	Molto veloce (AES, ecc.)	Ordini di grandezza più lenta
N utenti	N(N-1)/2 chiavi totali	Solo 2N chiavi totali
Usi tipici	Cifratura di dati (bulk)	Scambio chiavi, firma digitale, autenticazione

Uso combinato (pratica reale): la crittografia asimmetrica non sostituisce la simmetrica, la **completa**. In pratica si usa la pubblica per scambiare una chiave di sessione simmetrica, poi si cifra tutto il resto con quella chiave simmetrica (molto più veloce).

```
A → B: E_AES(Ks, m) || {Ks}_(KU_B) ↑ messaggio cifrato con AES ↑ chiave AES cifrata con RSA pubblica di B
```

Usi principali della crittografia a chiave pubblica:

Uso	Come funziona
Cifratura / Decifratura	Confidenzialità: si cifra con KU del destinatario, si decifra con KR
Firma digitale	Autenticità + integrità + non-ripudio: si firma con KR, si verifica con KU
Scambio di chiavi	Key establishment: es. Diffie-Hellman per concordare una chiave simmetrica
Autenticazione	Identificazione: dimostrare di possedere la chiave privata (es. challenge-response RSA)

2. RSA — Sintesi (Q17, Q19)

RSA (Rivest, Shamir, Adleman, 1977) è l'algoritmo a chiave pubblica più diffuso. Si basa sulla difficoltà di fattorizzare grandi numeri.

Generazione chiavi:

```
1. Scegli p, q primi grandi e segreti 2. n = p·q (pubblico, il modulo) 3. Φ(n) = (p-1)(q-1) (segreto) 4. Scegli e: GCD(e, Φ(n)) = 1 (pubblico) 5. Calcola d = e■¹ mod Φ(n) (segreto, con Euclide esteso) Chiave pubblica: KU = ■e, n■ Chiave privata: KR = ■d, n■
```

Operazione	Formula	Chiave usata	Chi
Cifratura	c = m■ mod n	KU = ■e,n■ del destinatario	Chiunque
Decifratura	m = c■ mod n	KR = ■d,n■ del destinatario	Solo il proprietario
Firma	s = H(m)■ mod n	KR = ■d,n■ del mittente	Il mittente
Verifica firma	h' = s■ mod n h' == H(m) ?	KU = ■e,n■ del mittente	Chiunque

> **Perché funziona:** poiché d·e ≡ 1 (mod Φ(n)), per il teorema di Eulero: c■ mod n = (m■)■ mod n = m^(ed) mod n = m^(1+kΦ(n)) mod n = m.

■■ Per gli esercizi RSA svolti (Es.15–18) vedi il PDF 'Riassunto_RSA.pdf'

3. Diffie-Hellman (DH) (Q18, Q24, Q25)

Diffie-Hellman (1976) è il primo algoritmo a chiave pubblica proposto. **Non cifra e non firma**: serve solo per **concordare una chiave segreta condivisa** tra due parti attraverso un canale pubblico (non sicuro). La sicurezza si basa sulla difficoltà del logaritmo discreto.

Setup (parametri pubblici condivisi da tutti):

```
p = numero primo grande (pubblico) g = radice primitiva modulo p (pubblico)
Tutti gli utenti concordano su p e g prima di iniziare.
```

Scambio chiavi tra A e B (Q18):

Passo	Alice (A)	Bob (B)
1. Chiave privata	Sceglie xA < p (segreto)	Sceglie xB < p (segreto)
2. Chiave pubblica	yA = g^xA mod p (pubblica)	yB = g^xB mod p (pubblica)
3. Scambio	Invia yA a B	Invia yB a A
4. Chiave condivisa	KAB = yB^xA mod p	KAB = yA^xB mod p
Risultato	**KAB = g^(xA·xB) mod p**	**KAB = g^(xA·xB) mod p ← stesso valore!**

> **Perché funziona:** un attaccante che osserva yA e yB deve calcolare g^(xA·xB) mod p conoscendo solo g^xA e g^xB. Per farlo dovrebbe calcolare xA o xB dal loro logaritmo discreto — problema computazionalmente difficile.

Vulnerabilità MITM (Q24):

```
DH è vulnerabile all'attacco Man-In-The-Middle se il canale non è
autenticato. L'attaccante M si inserisce tra A e B: A sceglie xA, calcola yA =
g^xA mod p M intercetta yA, sceglie xM, calcola yM = g^xM mod p M invia yM a B
fingendosi A B sceglie xB, calcola yB = g^xB mod p M intercetta yB M invia yM
a A fingendosi B Risultato: A crede di condividere KAB con B, ma condivide KAM
= g^(xA·xM) con M B crede di condividere KAB con A, ma condivide KMB =
g^(xM·xB) con M M decifra tutto, può leggere e modificare il traffico
```

Soluzione: DH autenticato — le chiavi pubbliche yA e yB vengono firmate digitalmente o certificate (PKI). Vedi Es.29 e sezione Key Establishment.

DH generalizzato per N parti (Q25):

Per 3 utenti A, B, C con chiavi private xA, xB, xC:

```
Round 1 — ognuno calcola la propria chiave pubblica: yA = g^xA mod p, yB =
g^xB mod p, yC = g^xC mod p Round 2 — ognuno eleva la chiave di un altro alla
propria chiave privata: A calcola: yB^xA = g^(xB·xA) B calcola: yC^xB =
g^(xC·xB) C calcola: yA^xC = g^(xA·xC) e li scambia Round 3 — chiave condivisa
finale: K = g^(xA·xB·xC) mod p (calcolabile da ognuno dei tre)
```

> In generale, per N parti servono N-1 round di scambio.

4. Esercizi DH Svolti

Es.20 — Verifica che 2 è radice primitiva di 11:

```
11 è primo → Φ(11) = 10. Dobbiamo mostrare che 2 genera tutti i 10 elementi: 2^1 mod 11 = 2 2^2 mod 11 = 4 2^3 mod 11 = 8 2^4 mod 11 = 16 mod 11 = 5 2^5 mod 11 = 32 mod 11 = 10 2^6 mod 11 = 64 mod 11 = 9 2^7 mod 11 = 128 mod 11 = 7 2^8 mod 11 = 256 mod 11 = 3 2^9 mod 11 = 512 mod 11 = 6 2^10 mod 11 = 1024 mod 11 = 1 Valori generati: {2,4,8,5,10,9,7,3,6,1} = {1,...,10} ✓ 2 è radice primitiva di 11 ■
```

Es.19 — Scambio DH con g=2, p=11:

```
Parametri pubblici: g=2, p=11 Esempio con xA=3, xB=4: A calcola: yA = 2^3 mod 11 = 8 B calcola: yB = 2^4 mod 11 = 16 mod 11 = 5 A e B si scambiano yA=8 e yB=5 A calcola: KAB = yB^xA mod p = 5^3 mod 11 = 125 mod 11 = 4 B calcola: KAB = yA^xB mod p = 8^4 mod 11 = 4096 mod 11 = 4 ✓ Chiave condivisa: KAB = 4 (L'attaccante vede solo g=2, p=11, yA=8, yB=5 — non può trovare KAB senza risolvere il logaritmo discreto)
```

Es.21 — DH con p=71, g=7, xA=5, xB=12:

```
i) Chiave pubblica di A: yA = g^xA mod p = 7^5 mod 71 7^2 = 49 7^4 = 49^2 = 2401 mod 71 = 2401 - 33·71 = 2401 - 2343 = 58 7^5 = 7^4 · 7 = 58·7 = 406 mod 71 = 406 - 5·71 = 406 - 355 = 51 yA = 51 ii) Chiave pubblica di B: yB = g^xB mod p = 7^12 mod 71 7^8 = 58^2 = 3364 mod 71 = 3364 - 47·71 = 3364 - 3337 = 27 7^12 = 7^8 · 7^4 = 27·58 = 1566 mod 71 = 1566 - 22·71 = 1566 - 1562 = 4 yB = 4 iii) Chiave condivisa: A calcola: KAB = yB^xA mod p = 4^5 mod 71 4^2 = 16 4^4 = 16^2 = 256 mod 71 = 256 - 3·71 = 43 4^5 = 4^4 · 4 = 43·4 = 172 mod 71 = 172 - 2·71 = 30 B calcola: KAB = yA^xB mod p = 51^12 mod 71 51^2 = 2601 mod 71 = 2601 - 36·71 = 2601 - 2556 = 45 51^4 = 45^2 = 2025 mod 71 = 2025 - 28·71 = 2025 - 1988 = 37 51^8 = 37^2 = 1369 mod 71 = 1369 - 19·71 = 1369 - 1349 = 20 51^12 = 51^8 · 51^4 = 20·37 = 740 mod 71 = 740 - 10·71 = 740 - 710 = 30 ✓ KAB = 30
```

5. Riepilogo Rapido

Concetto	In una riga	Domanda/Es.
Trapdoor function	Facile in avanti, impossibile invertire senza info segreta	Q17
Chiave pubblica	KU = ■e,n■ — nota a tutti	Q17
Chiave privata	KR = ■d,n■ — solo il proprietario	Q17
RSA cifratura	c = m■ mod n (con KU destinatario)	Q17, Es.15-17
RSA decifratura	m = c■ mod n (con KR destinatario)	Q17, Es.16-17
RSA firma	s = H(m)■ mod n (con KR mittente)	Q19
RSA verifica firma	h' = s■ mod n; se h'=H(m) → valida	Q19

DH parametri pubblici	p (primo grande), g (radice primitiva di p)	Q18
DH chiave pubblica	yA = g^xA mod p (xA è la chiave privata)	Q18, Es.19-21
DH chiave condivisa	KAB = yB^xA mod p = g^(xA·xB) mod p	Q18, Es.19-21
DH sicurezza	Si basa sulla difficoltà del logaritmo discreto	Q18
DH vulnerabilità MITM	Senza autenticazione, M può intercettare e sostituire le chiavi pubbliche	Q24
DH autenticato	Firmare yA e yB o usare certificati (PKI)	Q24, Es.29
DH di gruppo	N-1 round di scambio per N parti	Q25
Simm. vs asimm.	Asimm. per scambiare chiave → simm. per cifrare i dati (più veloce)	Q17

Fonti: Slide Veltri (198–239) + Stallings Cap.9 (pp.542–593) + Cap.10 sez.10.1 (pp.594–615)